Emergency Training Simulator POC

Markdown documentation PDF copy

POC threat model

Source: docs/security/poc-threat-model.md

Markdown stays editable. This PDF is the reading/share copy.

Boundary: this project is still a POC, not operational guidance.

POC threat model

This is a simple threat model for the current local backend demo.

It is written for the project as it exists now, not for the future ideal system.

What I am protecting right now

For this POC, the important things are:

- scenario state should not be changed directly by the client
- validation results should come from the backend
- logs should stay inside the intended log folder
- replay should be able to explain what happened
- weird input should fail safely

Main trust boundary

The client is outside the trust boundary.

That includes:

- fake trainee script
- future Unreal client
- future sensors
- future UI panels

The backend is the source of truth for:

- session state
- sequence order
- validation result
- final outcome
- replay/review data

Current risks

| Risk | What it means | Current handling | | --- | --- | --- | | Bad message shape | Client sends missing or extra fields | Pydantic rejects unexpected fields | | Path-like IDs | Client tries IDs like ../bad | IDs are limited to safe characters | | Huge payloads | Client sends giant nested JSON | Payload size/depth is limited | | Wrong sequence | Client skips or repeats sequence numbers | Session manager checks order | | Duplicate events | Client resends the same event ID | Session manager rejects duplicates | | Too many sessions | Client opens many local sessions | Session manager has a small active-session limit | | Too many actions | Client sends too many actions in one session | Session manager has a per-session action limit | | Client-owned truth | Client claims a final state | Backend ignores client state claims | | Log path abuse | Client tries to choose a log path | Logger derives the path from a safe session ID |

Risks not solved yet

These are real future issues, but they are not part of the current local POC:

- authentication
- authorization
- rate limiting
- TLS

- cloud/network exposure
- secrets handling
- malicious Unreal clients
- production log privacy
- sensor spoofing
- dependency scanning

Beginner-friendly summary

The main security rule is:

The client can say what action it wants to attempt. The backend decides what actually happened.